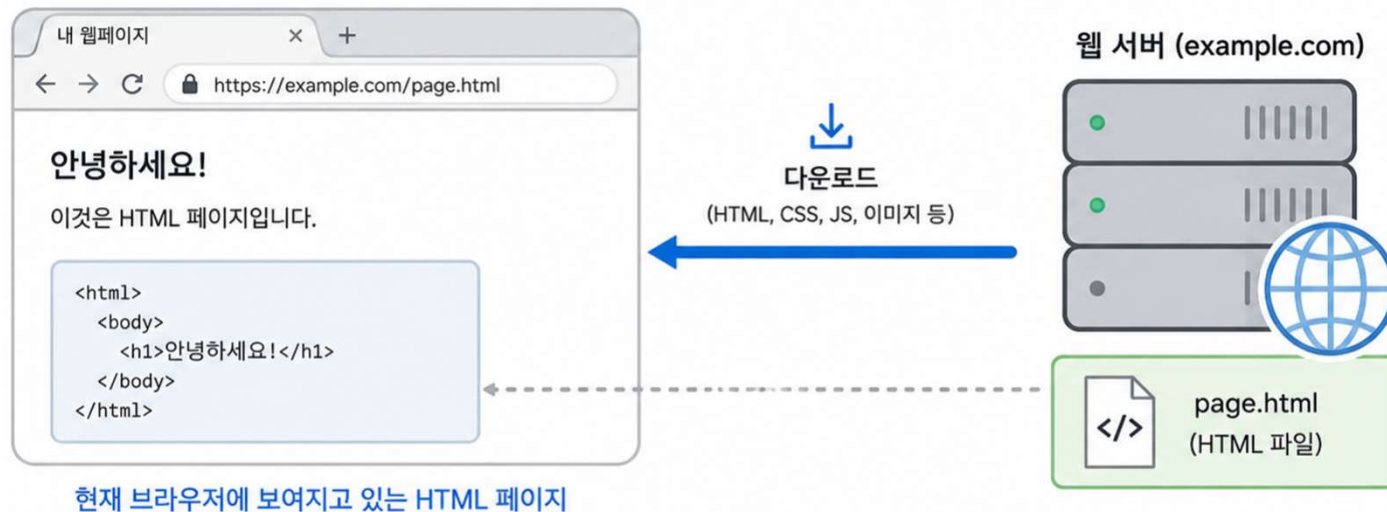


9. CORS

❖ Origin?

현재 브라우저에 보여지고 있는 HTML 페이지를
어디에서 다운로드했는지 **원산지 정보**



Origin 정보

<https://example.com:8080>

프로토콜
(http 또는 https)

호스트(도메인)
(server 이름)

포트 번호
(선택 사항)

(생략 시 기본 포트 사용
- https: 443, http: 80)

이 페이지의 Origin 은

<https://example.com:8080>

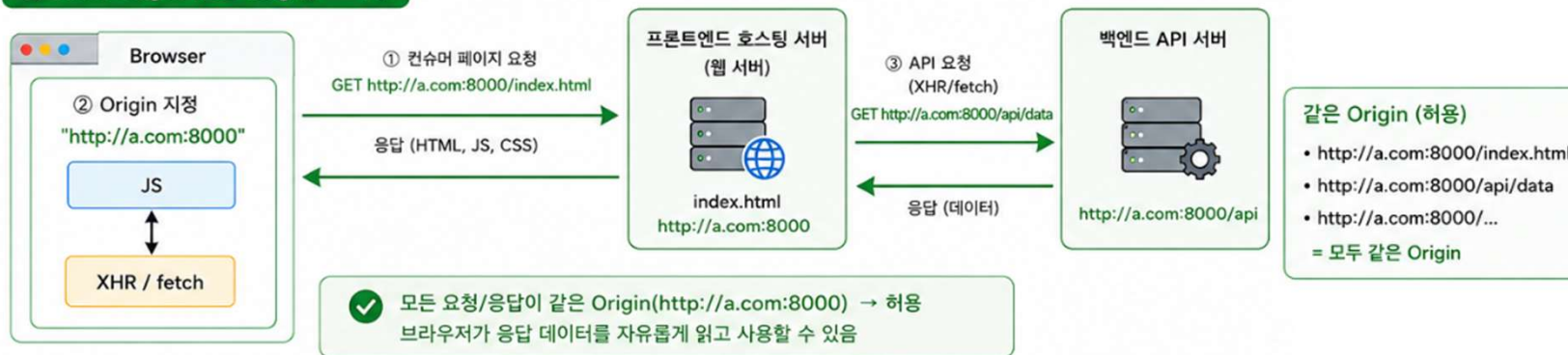
(이곳에서 페이지를 다운로드함)

9. CORS

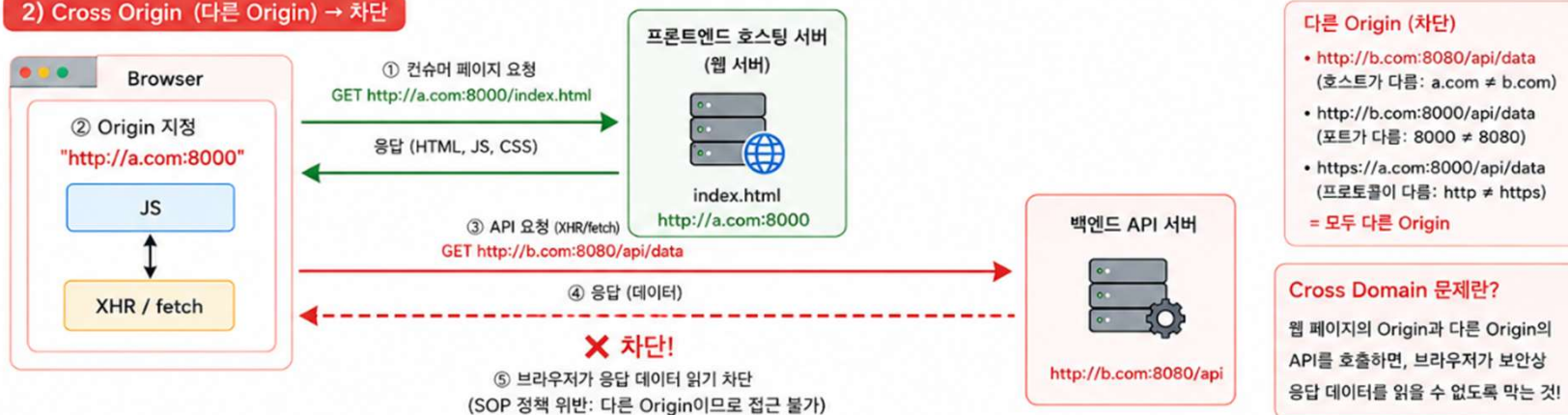
❖ SOP(Same Origin Policy)과 Cross Domain 문제

브라우저는 보안상 "자신이 다운로드 받은 페이지의 Origin과 같은 Origin"에만 자유롭게 데이터를 주고받을 수 있습니다.

1) Same Origin (같은 Origin) → 허용



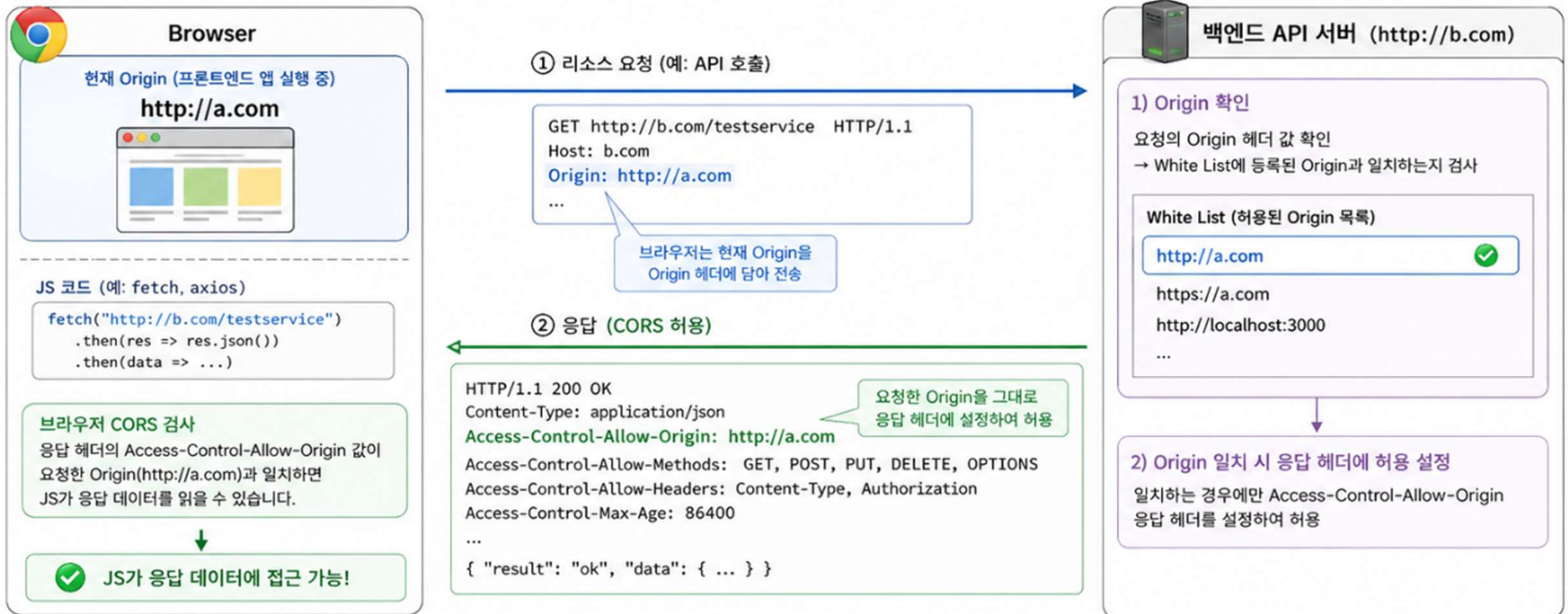
2) Cross Origin (다른 Origin) → 차단



9. CORS

❖CORS(Cross Origin Resource Sharing)

다른 Origin의 API 요청을 허용하려면, 서버가 허용된 Origin에 대해 응답 헤더를 설정해야 합니다.



9. CORS

❖ CORS를 아파트 보안에 비유하자면...

- 절대 모든 오리진을 허용해서는 안됨
 - Access-Control-Allow-Origin: * ---> 바람직하지 않은 설정

CORS는 “차단하는 것”이 아니라, “다른 출처를 허용해주는 규칙”입니다.



CORS 동작 과정 (아파트 보안 절차)

